

A18. Pràctica: Configuració d'un tallafocs amb UFW

0226. Seguretat informàtica

GRUP: SMX2C

RA4. Implanta mecanismes de seguretat en xarxa mitjançant la instal·lació i configuració de tallafocs, aplicant criteris de filtratge en funció de les necessitats d'ús.

NOM I COGNOMS: Posa el teu nom i cognoms.

DATA: Escribeu la data.

Enunciat de l'activitat:

Aquesta activitat es cenyeix a l'apartat NF5-AA4 (Tallafocs) del RA4: tipus de tallafocs, polítiques de filtratge, DMZ, i configuració pràctica amb UFW (Uncomplicated Firewall) a Linux.

IMPORTANT: si practiques sobre una màquina remota (per exemple, via SSH), recorda SEMPRE permetre el port d'administració (22/tcp) ABANS d'activar la denegació per defecte, o perdràs l'accés al sistema.

Part 1 · Configuració bàsica d'UFW

Pas 1. Instal·la UFW (si no ve preinstal·lat) i estableix una política de denegació per defecte en trànsit entrant, amb permissió per defecte en trànsit sortint:

```
$ apt install ufw
$ ufw default deny incoming
$ ufw default allow outgoing
```

Pas 2. Escenari: un servidor que ha d'oferir SSH (administració), un lloc web (HTTP) i HTTPS, i que ha de bloquejar explícitament una IP que ha estat detectada fent atacs de força bruta. Configura les regles corresponents i activa el tallafocs:

```
$ ufw allow 22/tcp comment 'SSH administracio'
$ ufw allow 80/tcp comment 'Servidor web public'
$ ufw allow 443/tcp comment 'HTTPS'
$ ufw deny from 203.0.113.50 comment 'IP maliciosa bloquejada'
$ ufw enable
$ ufw status verbose
```

```
Terminal - UFW (tallafocs)

$ ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
$ ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
$ ufw allow 22/tcp comment "SSH administracio"
Skipping adding existing rule
$ ufw allow 80/tcp comment "Servidor web public"
Skipping adding existing rule
$ ufw allow 443/tcp comment "HTTPS"
Skipping adding existing rule
$ ufw deny from 203.0.113.50 comment "IP maliciosa bloquejada"
Skipping adding existing rule
$ ufw enable
Firewall is active and enabled on system startup

$ ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere # SSH administracio
80/tcp ALLOW IN Anywhere # Servidor web public
443/tcp ALLOW IN Anywhere # HTTPS
Anywhere DENY IN 203.0.113.50 # IP maliciosa bloquejada
```

Captura real: configuració completa d'un tallafocs UFW amb política de denegació per defecte en trànsit entrant, tres regles d'"allow" (SSH, HTTP, HTTPS) amb comentaris explicatius, una regla de "deny" per IP, i el resultat final amb "ufw status verbose".

Reprodueix aquesta configuració (o una similar, adaptada a un escenari propi) a una màquina virtual Linux pròpia [CAPTURA] i respon: a) Quina línia de la sortida de "ufw status verbose" indica la política per defecte? b) Per què és important afegir un comentari ("comment") a cada regla, en un entorn professional amb desenes de regles acumulades al llarg del temps?

Part 2 · Gestió i manteniment de regles

Pas 3. Consulta les regles numerades i elimina'n una (per exemple, si el servei HTTPS es dona de baixa):

```
$ ufw status numbered
$ ufw delete 3 # substitueix pel número real de la regla HTTPS
```

```
Terminal – UFW (tallafocs)

$ ufw status numbered
Status: active

      To Action From
      --
[ 1] 22/tcp ALLOW IN Anywhere # SSH administracio
[ 2] 80/tcp ALLOW IN Anywhere # Servidor web public
[ 3] 443/tcp ALLOW IN Anywhere # HTTPS
[ 4] Anywhere DENY IN 203.0.113.50 # IP maliciosa bloquejada

# Es decideix eliminar la regla 3 (HTTPS ja no cal, el servei es dona de baixa)
$ ufw delete 3
Deleting:
allow 443/tcp comment 'HTTPS'
Proceed with operation (y|n)? Rule deleted

$ ufw status numbered
Status: active

      To Action From
      --
[ 1] 22/tcp ALLOW IN Anywhere # SSH administracio
[ 2] 80/tcp ALLOW IN Anywhere # Servidor web public
[ 3] Anywhere DENY IN 203.0.113.50 # IP maliciosa bloquejada
```

Captura real: llistat numerat de regles, eliminació de la regla número 3 (HTTPS), i comprovació que ha desaparegut del llistat numerat final.

Reprodueix-ho al teu equip [CAPTURA] i respon: a) Per què és útil el llistat NUMERAT en lloc del llistat normal a l'hora de fer manteniment de regles? b) Si en un servidor real trobessis una regla molt antiga, sense comentari, que ningú recorda per què hi és, quin seria el procediment prudent abans d'eliminar-la (relaciona-ho amb el risc de tallar un servei en producció)?

Part 3 · Disseny de xarxa amb DMZ

Una empresa vol exposar a Internet el seu servidor web corporatiu, mantenint el servidor de fitxers intern (amb dades de nòmines i contractes) totalment inaccessible des de fora. Dissenya, en forma d'esquema o llista, una arquitectura de xarxa amb DMZ que resolgui aquest requisit, indicant: 1) on situaries el servidor web; 2) on situaries el servidor de fitxers; 3) quines regles bàsiques de tallafocs (permetre/denegar, origen/destí) aplicaries entre Internet, la DMZ i la xarxa interna.

Cas pràctic final

Ets el tècnic de sistemes d'una empresa que acaba de patir un incident: un atacant va escanejar la xarxa i va trobar un servidor de bases de dades (port 3306, MySQL) accessible directament des d'Internet, sense cap tallafocs. Elabora un informe tècnic que reculli: 1) quina política de filtratge (denegació o permissió per defecte) recomanaries per a aquest servidor, i per què; 2) les regles UFW concretes que aplicaries perquè el servidor de bases de dades només sigui accessible des del servidor d'aplicacions intern (per exemple, 10.0.0.5), i des de cap altre lloc; 3) si, a més del tallafocs, recomanaries alguna altra mesura de seguretat addicional (relaciona-ho amb el que heu vist sobre IDS/IPS al RA3); 4) per què un tallafocs, per si sol, no hauria estat suficient per evitar completament el risc si el servidor també tenia una contrasenya feble.

Fonts: Repositori "Materials" (GitHub, SMX-0226SI), NF5/AA4-Tallafocs.md (CC-BY-SA-4.0); UFW — documentació oficial (help.ubuntu.com/community/UFW); Cloudflare, "What is a firewall?".